STUDI INDEPENDEN CYBERSECURITY

RENCANA PROYEK AKHIR

Pentest lab terisolasi dengan target sengaja rentan

KampusMart | 65 mahasiswa | 13 kelompok x 5 | 3 varian

Draft perencanaan instruktur

13 Oktober 2026

RINGKASAN

- Satu skenario fiktif dengan tiga varian setara.
- Setiap kelompok memiliki instance dan data sintetis sendiri.
- Tujuan: temukan, buktikan, perbaiki, dan retest kelemahan.
- Batas: hanya jaringan lab; tanpa target publik atau data nyata.

STRUKTUR KELAS

Varian A: 5 kelompok Varian B: 4 kelompok Varian C: 4 kelompok

Setiap varian memuat tiga kelas temuan dan dinilai dengan rubrik yang sama.

Angka infrastruktur adalah estimasi awal yang perlu diuji dengan pilot.

1. Ringkasan keputusan

Rencana ini memakai satu skenario fiktif bernama KampusMart dengan tiga varian yang setara. Untuk 65 mahasiswa: 13 kelompok berisi lima orang, dibagi ke varian A, B, dan C masing-masing 5, 4, dan 4 kelompok. Setiap kelompok memperoleh instance target terpisah.

Setiap varian menguji cakupan dan tingkat kesulitan yang sama: satu modul CVE, satu kelemahan kontrol akses, dan satu kelemahan alur bisnis. Yang berubah adalah nama endpoint, peran akun, data uji, dan letak kondisi pemicunya. Dengan begitu rubrik tetap seragam, sementara menyalin langkah kelompok lain menjadi kurang berguna.

Keputusan desain

- Skenario: KampusMart, toko kebutuhan kampus fiktif dengan web, API, akun mahasiswa, staf, dan admin.
- Deployment: satu stack target per kelompok; mahasiswa menjalankan browser dan alat uji dari laptop masing-masing.
- CVE dasar: Apache HTTP Server 2.4.49, CVE-2021-41773, dengan bukti terbatas pada file penanda sintetis. Perbaikan diuji dengan versi 2.4.51 atau lebih baru.
- Cakupan temuan: CVE, kontrol akses berbasis objek, dan validasi alur bisnis.
- Semua akses dibatasi ke jaringan kelas atau localhost; target tidak memiliki jalur ke internet publik.
- Nilai mengutamakan bukti yang dapat diulang, dampak yang terukur, perbaikan, dan retest; bukan jumlah temuan.

Asumsi dan hal yang perlu dikonfirmasi sebelum pelaksanaan

Angka server di dokumen ini adalah titik awal perencanaan, bukan hasil benchmark. Rencana kalender memakai delapan milestone yang dapat direntangkan mengikuti durasi studi independen. Model hosting akhir perlu dipilih: target di server kampus atau Compose lokal pada laptop mahasiswa.

2. Tujuan belajar dan brief mahasiswa

Hasil belajar

- Menentukan batas scope dan membuat peta aset, peran, alur aplikasi, serta endpoint.
- Memeriksa apakah komponen dan konfigurasinya benar-benar memenuhi kondisi sebuah CVE; kecocokan nomor versi saja tidak cukup.
- Menguji kontrol akses dan aturan bisnis menggunakan akun serta data sintetis yang disediakan.
- Membedakan indikasi scanner dari temuan yang sudah direproduksi dan memiliki dampak.
- Menyusun bukti minimal, menjelaskan akar masalah, mengusulkan perbaikan, lalu membuktikan retest.

Brief proyek untuk mahasiswa

KampusMart meminta tim melakukan penetration test terbatas terhadap instance yang ditugaskan. Tujuan tim adalah menemukan kelemahan yang dapat dibuktikan, menjelaskan dampaknya pada akun dan data fiktif, serta memberikan rekomendasi yang dapat diuji. Scope hanya mencakup alamat, akun, dan layanan di lembar penugasan tim.

Tidak ada pengujian terhadap sistem kampus sungguhan, akun di luar lab, jaringan internet, atau layanan kelompok lain. Mahasiswa tidak diminta menghapus data, melakukan denial of service, mempertahankan akses, atau mengambil data selain marker sintetis yang disediakan.

Alur dan peran aplikasi

- Mahasiswa: melihat produk, membuat pesanan, membaca invoice, dan mengirim tiket bantuan.
- Staf toko: mengelola status pesanan dan menangani tiket.
- Admin: mengelola katalog dan melihat ringkasan operasional.
- Data uji: nama fiktif, alamat contoh, invoice buatan, dan produk nonnyata. Jangan memakai data pribadi atau kredensial sungguhan.

3. Spesifikasi target dan temuan yang ditanam

Komponen target

- Web app: antarmuka KampusMart dengan login, katalog, checkout, invoice, dan tiket bantuan.
- API: endpoint untuk profil, pesanan, invoice, kupon, dan tiket.
- Database: satu database per kelompok dengan fixture sintetis dan akun berperan berbeda.
- Layanan CVE: container Apache terpisah dari aplikasi utama, hanya dapat dijangkau dari jaringan kelas.
- Observability: log request dan log aplikasi yang dapat dibaca pengajar; tidak perlu menyimpan token autentikasi mahasiswa.

Tiga kelas temuan yang sama di semua varian

1) CVE Apache path traversal: layanan uji memakai build terdampak yang telah dipatok. Tujuan pembuktian hanya membaca marker sintetis yang disiapkan pengajar. Jangan menambahkan CGI atau perilaku eksekusi kode sebagai bagian wajib. Catat kondisi konfigurasi yang dibutuhkan dan validasi advisory resmi.

2) Broken object-level authorization: akun berperan rendah mencoba membaca satu objek pesanan, invoice, atau tiket milik akun uji lain. Hasil yang diterima hanya record sintetis dalam instance kelompok itu.

3) Business logic / workflow: aturan kupon, status pesanan, atau refund menerima transisi yang tidak semestinya. Dampak dibuat terbatas dan dapat direset; jangan menghubungkan ke pembayaran atau layanan eksternal.

Kriteria tiap temuan

- Ada kondisi awal, akun uji, langkah reproduksi tingkat tinggi, respons atau bukti yang diamati, dan hasil yang diharapkan.
- Dampak menunjukkan akses/perubahan terhadap data sintetis atau aturan bisnis simulasi, bukan klaim yang tidak didukung.
- Rekomendasi menunjuk kontrol yang harus diperbaiki; retest membuktikan kondisi rentan tidak lagi terjadi.
- Temuan duplikat antar kelompok tidak mengurangi nilai bila analisis, bukti, dan retest kelompok tersebut mandiri.

4. Rancangan tiga varian dan keadilan penilaian

Semua varian berasal dari satu codebase atau template konfigurasi yang sama. Hindari memelihara tiga aplikasi yang tumbuh terpisah. Buat manifest per varian yang menetapkan route, akun, ID objek, kondisi workflow, marker, serta daftar expected findings untuk pengajar.

Varian A - Fokus pesanan

- Kelompok: 5. Endpoint kontrol akses berpusat pada pesanan dan invoice; variasi workflow berada di aturan kupon.
- Data: ID pesanan dan akun berbeda untuk tiap kelompok; CVE service dan tingkat bukti sama dengan varian lain.

Varian B - Fokus invoice dan tiket

- Kelompok: 4. Jalur kontrol akses berada di invoice atau tiket bantuan; variasi workflow ada pada perubahan status pesanan.
- Nama route, urutan record, dan akun berbeda; jumlah serta dampak maksimal temuan tetap sama.

Varian C - Fokus refund

- Kelompok: 4. Jalur kontrol akses berada di ringkasan refund; variasi workflow ada pada validasi klaim/refund simulasi.
- Data dan prasyarat berbeda, tetapi bukti sukses tetap record marker sintetis yang setara.

Aturan kesetaraan

- Ketiga varian memuat tiga kelas temuan yang sama dan memerlukan level akses awal yang setara.
- Samakan panjang alur, jumlah prasyarat, kualitas petunjuk, batas dampak, dan langkah retest.
- Pengajar menjalankan pilot blind test pada setiap varian sebelum kelas dimulai; catat waktu penemuan dan titik buntu.
- Bekukan image/config setelah pilot. Beri setiap kelompok kredensial, data, port atau hostname, dan marker unik.
- Jangan mengumumkan answer key atau membagikan manifest pengajar ke mahasiswa.

5. Arsitektur lab dan isolasi

Topologi yang disarankan

Laptop mahasiswa (browser, Burp atau ZAP, terminal) -> VPN kelas atau VLAN lab -> gateway dengan allowlist -> instance target khusus kelompok. Jaringan internal target menghubungkan web/API, database, layanan CVE, dan callback sink simulasi bila memang diperlukan. Panel pengajar/log berada di jalur administrasi terpisah.

Untuk kelas lokal, publikasikan port target hanya ke localhost. Untuk server bersama, izinkan akses hanya dari VPN/VLAN kelas dan rentang port yang ditugaskan. Gunakan aturan firewall deny-by-default antar kelompok.

Kontrol teknis minimum

- Tidak ada IP publik atau port-forward dari internet ke target.
- Blokir egress dari target. Bila modul perlu callback, arahkan hanya ke sink internal milik lab.
- Jangan hubungkan container target ke jaringan publik sekaligus jaringan internal. Docker Compose mendukung network internal tanpa koneksi eksternal; validasi aturan pada host lab.
- Jangan gunakan privileged container, host networking, mount direktori host yang tidak perlu, atau Docker socket.
- Batasi CPU, RAM, disk, jumlah proses, ukuran upload, dan masa hidup instance.
- Pisahkan volume dan database tiap tim; tidak ada shared writable volume.
- Gunakan image tag dan digest yang dipatok, SBOM/daftar komponen, serta backup image yang sudah disiapkan offline.
- Simpan log secukupnya untuk pembelajaran dan debugging; minimalkan token sesi dan data pengenal.

Reset dan pemulihan

Sediakan reset per kelompok yang menghapus state lab yang dapat dipulihkan, mengisi ulang fixture sintetis, memutar ulang akun/marker, dan memeriksa health check. Buat snapshot sebelum sesi. Siapkan tombol suspend seluruh range bila ada salah konfigurasi jaringan, lonjakan resource, atau akses keluar yang tidak direncanakan.

6. Spesifikasi perangkat dan deployment

Mahasiswa menjalankan target lokal

- Minimum praktis per laptop: 4 core, RAM 16 GB, ruang kosong 60-80 GB, dan dukungan virtualisasi/container yang berfungsi.
- Lebih nyaman: 8 core dan RAM 32 GB untuk menjalankan target, proxy, browser, dan beberapa alat bersamaan.
- Target satu kelompok: alokasikan sekitar 2-3 vCPU, RAM 4-6 GB, dan disk 20-40 GB; ukur setelah stack dan logging final.

Server bersama untuk 13 instance target

- Titik awal yang disarankan: 24-32 vCPU, RAM 96 GB, NVMe 1 TB, jaringan 1 GbE, backup terpisah.
- RAM 64 GB dapat menjadi konfigurasi hemat jika target ringan dan beban scanner dibatasi; uji dengan 13 tim sebelum memutuskan.
- Anggaran ini mengasumsikan mahasiswa memakai laptop untuk attacker tools. Jika server juga menampung attacker VM tiap tim, siapkan tambahan sekitar 2 vCPU dan 4 GB RAM per VM; hitung ulang sebelum membeli.
- Sisakan kapasitas untuk OS, log, image cache, monitoring, dan reset serentak; gunakan limit per container.

Uji kapasitas sebelum kelas

- Jalankan 13 instance dengan data penuh dan health checks aktif.
- Simulasikan pemindaian ringan serentak dan reset dua atau tiga kelompok.
- Pantau CPU, RAM, disk I/O, latensi, log growth, dan koneksi antar kelompok.
- Jika laptop mahasiswa beragam, sediakan satu server lab sebagai jalur utama dan Compose lokal sebagai fallback.

Pilihan pengelolaan

Gunakan Docker Compose untuk proof of concept dan pilot. Untuk server multiuser, tempatkan tiap kelompok di VM atau namespace/range terisolasi dengan aturan jaringan yang diuji. VM lebih mudah dipahami sebagai batas operasional bagi modul yang mengandung CVE berdampak tinggi.

7. Pembagian 13 kelompok dan rotasi peran

Kelompok A1-A5 memakai varian A; B1-B4 varian B; C1-C4 varian C. Setiap kelompok berisi lima mahasiswa. Jika jumlah kehadiran berubah, pertahankan ukuran empat sampai lima orang dan sesuaikan jumlah instance, bukan menggabungkan dua tim pada satu target.

Peran awal per kelompok

- Koordinator/scope: memegang scope, jadwal, daftar akun, dan pembagian tugas.
- Recon/pemetaan: membuat peta fitur, teknologi yang terlihat, dan endpoint.
- Web/API: menguji alur aplikasi dan kontrol akses.
- CVE/config: memeriksa advisory, versi, konfigurasi, dan status patch.
- Evidence/QA: menjaga catatan reproduksi, menguji ulang klaim, serta menyiapkan laporan dan retest.

Peran bukan batas kerja. Rotasikan setidaknya sekali sebelum validasi final agar setiap mahasiswa melakukan pengujian langsung. Catat nama pelaksana pada evidence log. Pada presentasi, setiap anggota menjelaskan satu bukti atau retest yang ia kerjakan.

Aturan kolaborasi

- Berbagi konsep dan advisory publik diperbolehkan; jangan menyalin laporan atau bukti kelompok lain.
- Temuan antar tim boleh sama karena target sengaja mengandung pola yang sama; nilai berdasarkan kerja dan pembuktian mandiri.
- Gunakan kanal kelas hanya untuk pertanyaan operasional; detail answer key disimpan pengajar.

8. Rangkaian proyek: delapan milestone

Milestone ini adalah urutan kerja yang bisa dipadatkan atau direntangkan. Setiap tahap menghasilkan artefak kecil agar pengajar dapat memberi umpan balik sebelum laporan akhir.

M0 - Orientasi dan keselamatan

- Brief scope, aturan berhenti, setup tools, akun uji, akses target, dan latihan menulis request/response dengan data sintetis.

M1 - Scope dan rencana pengujian

- Submit peta aset, peran, batas target, risiko, dan urutan pengujian sebelum melakukan tes aktif.

M2 - Recon dan model aplikasi

- Petakan halaman, API, alur pesanan, kontrol autentikasi, serta versi komponen yang terlihat. Pisahkan fakta, asumsi, dan belum diketahui.

M3 - Pemeriksaan CVE

- Baca advisory primer, catat affected version dan prasyarat konfigurasi, tentukan bukti sukses aman, dan bandingkan dengan konfigurasi target.

M4 - Pengujian kontrol akses dan workflow

- Gunakan akun/objek uji yang diberikan. Uji satu perubahan pada satu waktu dan catat respons yang relevan.

M5 - Validasi dampak

- Reproduksi temuan pada kondisi bersih; buktikan dampak dengan record marker saja. Hentikan setelah bukti minimum diperoleh.

M6 - Remediasi dan retest

- Gunakan patch/config yang disediakan atau patch latihan. Ulangi kasus uji untuk memastikan temuan tidak lagi dapat direproduksi.

M7 - Laporan dan presentasi

- Kirim laporan final, bukti, rekomendasi, retest, pembagian kontribusi, dan presentasi lisan singkat.

9. Artefak mahasiswa dan rubrik penilaian

Paket pengumpulan

- Scope statement dan peta permukaan yang sudah disetujui.
- Evidence log bertanggal: tujuan, akun/peran, kondisi awal, request/response yang sudah disanitasi, observasi, dan hasil.
- Laporan tiap temuan: ringkasan, langkah reproduksi, dampak terbatas, akar masalah, rekomendasi, dan batasan.
- Retest: hasil sebelum/sesudah dan kondisi versi/konfigurasi yang diuji.
- Lampiran kontribusi individual dan refleksi singkat tentang satu keputusan teknis.

Rubrik 100 poin

- Scope, disiplin keselamatan, dan pencatatan: 15 poin. Wajib lulus scope gate; aktivitas di luar scope menghentikan pengujian dan ditangani pengajar.
- Metodologi dan pemetaan aplikasi: 10 poin. Cakupan jelas, observasi dapat diverifikasi, asumsi diberi label.
- Kualitas reproduksi dan bukti: 20 poin. Kondisi, langkah, respons, dan hasil cukup untuk diulang.
- Validasi dampak: 15 poin. Dampak konkret pada data/aturan sintetis, klaim proporsional.
- Analisis CVE dan akar masalah: 10 poin. Advisory, versi, prasyarat, dan konfigurasi diperiksa.
- Remediasi dan retest: 15 poin. Rekomendasi mengatasi penyebab, retest menunjukkan hasil.
- Kualitas laporan dan komunikasi: 5 poin. Jelas, singkat, dapat ditindaklanjuti.
- Pemeriksaan individual: 10 poin. Tiap anggota menjelaskan bukti atau retest yang ia lakukan.

Jangan memberi bonus untuk jumlah request, jumlah payload, atau banyaknya temuan mentah. Temuan scanner tanpa validasi tidak dihitung sebagai temuan terbukti.

10. Runbook pengajar dan gerbang kesiapan

Sebelum cohort

- Tetapkan host, zona waktu, durasi, kebijakan akses, dan kontak pengajar untuk penghentian lab.
- Tinjau CVE dari advisory resmi; bangun image pin, cek konfigurasi, uji marker aman, lalu patch dan retest.
- Bangun tiga varian dari template; jalankan pilot blind test dan samakan tingkat kesulitan.
- Buat 13 manifest kelompok: varian, endpoint, akun uji, data, target host/port, marker, dan prosedur reset.
- Uji isolasi antar tim, blokir egress, akses dari jaringan luar kelas, reset, backup, dan logging.
- Buat instructor answer key dan simpan terpisah dari paket mahasiswa.

Awal setiap sesi

- Pastikan daftar host dan instance sesuai manifest; health check hijau.
- Ingatkan scope, batas bukti, dan cara melaporkan salah konfigurasi.
- Pantau resource dan log; hentikan instance jika ada trafik keluar atau gangguan lintas kelompok.

Akhir sesi

- Simpan artefak kelas yang diperlukan, reset instance sesuai kebijakan retensi, dan cek instance kembali sehat.
- Setelah final, nonaktifkan akses mahasiswa, simpan rubrik dan versi image, lalu matikan range.

Gate go/no-go

- GO hanya jika scope tertulis, target terisolasi, semua varian lulus pilot, CVE proof dibatasi, reset bekerja, dan owner operasional tersedia.
- NO-GO jika target dapat dijangkau dari internet publik, egress belum dibatasi, marker menyentuh data nyata, atau patch/retest tidak dapat direproduksi.

11. Risiko utama, mitigasi, dan referensi

Risiko operasional

- Target rentan terekspos keluar: gunakan VPN/VLAN, firewall deny-by-default, tanpa IP publik, dan uji dari jaringan nonkelas.
- Serangan antar kelompok: instance, database, volume, kredensial, serta aturan jaringan per kelompok.
- Scanner menghabiskan resource: batasi rate/beban melalui aturan kelas, CPU/RAM quota, monitoring, dan tombol suspend.
- Perbedaan kesulitan varian: satu template kode, pilot blind, rubrik bersama, manifest pengajar.
- CVE/build tidak konsisten: pin versi dan digest, simpan image offline, catat advisory serta syarat konfigurasi, retest sebelum cohort.
- Data sensitif masuk log: hanya data sintetis, minimisasi log, dan prosedur hapus/reset yang teruji.

Referensi primer

- OWASP Juice Shop, aplikasi latihan rentan yang mencakup banyak kategori keamanan web: https://devguide.owasp.org/en/07-training-education/01-vulnerable-apps/01-juice-shop/
- OWASP WebGoat, lingkungan latihan aplikasi web yang sengaja rentan: https://owasp.org/projects/webgoat?tab=start
- Apache HTTP Server Security Vulnerabilities, affected versions, syarat, dan perbaikan CVE-2021-41773/CVE-2021-42013: https://httpd.apache.org/security/vulnerabilities_24.html
- NVD CVE-2021-44228 untuk penilaian Log4Shell sebagai modul lanjutan, bukan baseline: https://nvd.nist.gov/vuln/detail/CVE-2021-44228
- Docker Compose networking, termasuk jaringan internal tanpa konektivitas eksternal: https://docs.docker.com/compose/how-tos/networking/

Catatan CVE: Apache 2.4.49/2.4.50 dan CVE terkait memiliki syarat konfigurasi yang harus dikaji dari advisory. Rencana ini membatasi bukti pada marker sintetis dan tidak menjadikan eksekusi kode sebagai target latihan. NVD dan advisory vendor dapat berubah; pengajar harus mengulang pemeriksaan versi dan prasyarat tepat sebelum image dibekukan.

Keputusan lanjutan untuk pengajar

- Pilih server kampus terisolasi atau deployment lokal per kelompok.
- Tentukan tanggal dan panjang kalender; milestone delapan tahap dapat disesuaikan.
- Setujui CVE dasar setelah pilot build berhasil; bila tidak stabil, gunakan challenge simulasi yang setara.
- Tentukan siapa yang bertanggung jawab atas host, VPN, backup, dan penghentian lab.